Clase 318 — Gestión del programa de vulnerabilidades

> Parte: **17 — Profundización para certificaciones** · Fuente: *CompTIA CySA+ (CS0-003) Study Guide — Chapple & Seidl · NIST SP 800-40 Rev.4* ⏱️ Duración estimada: **120 min** · Nivel: **Avanzado**

🎯 Objetivo

Construir y operar un **programa de gestión de vulnerabilidades (VM)** completo: no un escaneo aislado, sino un ciclo continuo de descubrimiento, priorización basada en riesgo, remediación con SLAs y medición. Aprenderás a priorizar con **CVSS + EPSS + CISA KEV** en lugar de perseguir solo el número más alto, y a demostrar mejora con métricas —material del dominio de *Vulnerability Management* de CySA+ y de NIST SP 800-40.

📚 Resultados de aprendizaje

Al finalizar, el alumno podrá:

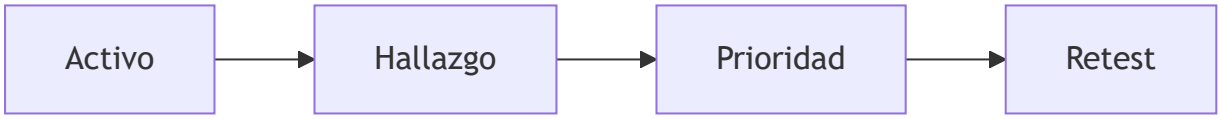
1. **Describir** las fases del ciclo de VM (inventario, descubrimiento, análisis, priorización, remediación, verificación, mejora).
2. **Priorizar** vulnerabilidades combinando severidad (CVSS), probabilidad de explotación (EPSS) y explotación activa (KEV).
3. **Definir** SLAs de remediación por criticidad y activos, alineados con el apetito de riesgo.
4. **Calcular** métricas clave: MTTR, tasa de remediación, densidad de vulnerabilidades, cobertura de escaneo, envejecimiento (aging).
5. **Diseñar** un pipeline de VM con roles, cadencia y flujo de excepciones.

🗺️ Temas

#	Tema	Por qué importa
1	Ciclo de vida de VM	VM es un proceso continuo, no un evento
2	Inventario y cobertura de activos	No se protege lo que no se conoce
3	Descubrimiento: escaneo autenticado vs no autenticado	El autenticado ve mucho más y con menos falsos positivos
4	CVSS (Base/Temporal/Environmental)	Severidad estándar, pero no es riesgo por sí solo
5	EPSS	Probabilidad de explotación en 30 días
6	CISA KEV	Vulnerabilidades explotadas *activamente* — máxima prioridad
7	SLAs de remediación y excepciones	Convierten hallazgos en compromisos medibles
8	Métricas y madurez del programa	Demuestran reducción de riesgo en el tiempo

🧠 Modelo mental y caso de decisión

El programa convierte inventario y hallazgos en tratamiento verificable, no en una carrera por cerrar conteos.



Caso razonado. Un crítico no desplegado recibe menos prioridad que una vulnerabilidad explotada en servicio público.

📓 Glosario operativo complementario

Término	Definición
Evidencia	Información cuya procedencia y relación con un criterio pueden revisarse.
Supuesto	Condición declarada de la que depende una conclusión.
Riesgo residual	Exposición que permanece después del tratamiento.

✅ Criterio de dominio

El alumno demuestra dominio cuando explica el diagrama, resuelve el caso con evidencia, declara límites y puede defender por qué su decisión cambia si cambia un supuesto.

Cómo lo nombra el catálogo CWE y qué cambia al priorizar

Un programa de gestión de vulnerabilidades puede trabajar sobre tres niveles de datos, y mezclarlos es una fuente clásica de métricas engañosas. El **CVE** es la vulnerabilidad pública concreta; la **instancia** es ese CVE

en un activo, con dueño, exposición y plazo; y el **CWE** es la causa común que agrupa muchos CVE. Los dos primeros alimentan la cola de trabajo; el tercero alimenta la **prevención**: si una causa (inyección SQL, `CWE-89`; credenciales embebidas, `CWE-798`; falta de autorización, `CWE-862`) aparece en muchos hallazgos, el remedio es de proceso y no de parche, y la métrica útil es la recurrencia de la causa, no el número de tickets.

La priorización de la clase (CVSS, EPSS, KEV) se refina con tres precisiones de la clase 369. Primera, **ningún umbral de EPSS tiene autoridad universal**; el 0,10 del laboratorio es un valor de ejemplo. Segunda, **la exposición del activo cambia el plazo del mismo CVE**: CISA BOD 26-04 (10 de junio de 2026, obligatoria para agencias civiles federales de EE. UU. y referencia para los demás) usa exposición, KEV, automatización e impacto técnico para dar plazos de 3, 14 o 60 días o la próxima actualización, con triaje forense si hay explotación confirmada y control total. Tercera, **un dato ausente no es un dato negativo**: la ausencia de un CVE en KEV o en EPSS significa «no sabemos». Con el priorizador del programa puedes reproducirlo: `python labs/devsecops-pipeline/priorizar.py --instantanea labs/devsecops-pipeline/datos/casos-cwe-cve.json --bod-26-04`.

📖 Definiciones y características

- **Gestión de vulnerabilidades (VM):** proceso continuo de identificar, evaluar, tratar y reportar vulnerabilidades. Característica clave: cíclico y basado en riesgo, no un escaneo puntual.
- **Escaneo autenticado (credentialed):** el escáner inicia sesión en el activo y lee versión de paquetes/parches. Característica clave: mucho más preciso y con menos falsos positivos que el no autenticado.
- **CVSS (Common Vulnerability Scoring System):** puntúa la severidad técnica de 0.0 a 10.0. **Base** (intrínseca), **Temporal** (madurez del exploit) y **Environmental** (ajuste al contexto propio). Característica clave: mide severidad, **no** probabilidad ni impacto de negocio.
- **EPSS (Exploit Prediction Scoring System):** probabilidad (0–1) de que una CVE sea explotada en los próximos 30 días, según datos observados. Característica clave: complementa a CVSS con una estimación de probabilidad de explotación.
- **CISA KEV (Known Exploited Vulnerabilities):** catálogo de CVEs con explotación **confirmada en la práctica**. Característica clave: si una CVE está en KEV hay explotación observada y pasa a las prioridades más altas sin importar su CVSS; el plazo concreto depende de la exposición del activo.
- **SLA de remediación:** plazo máximo para corregir según criticidad (p. ej. Crítica 7–15 días, Alta 30, Media 90). Característica clave: hace exigible la remediación y permite medir cumplimiento.
- **MTTR (Mean Time To Remediate):** tiempo medio desde detección hasta corrección. Característica clave: métrica central de eficiencia del programa.
- **Excepción / risk acceptance:** decisión formal y temporal de no remediar, con dueño, justificación, compensaciones y fecha de revisión. Característica clave: documentada y con caducidad, nunca "para siempre".

🧰 Herramientas y preparación

Monta un laboratorio de VM aislado (nunca escanees activos ajenos sin autorización):

- **Escáner:** OpenVAS/Greenbone (gratuito) o Nessus Essentials en una VM.
- **Objetivo de práctica:** Metasploitable 2/3 o una VM con software antiguo, en red host-only.
- **Fuentes de priorización:** API pública de EPSS (FIRST.org), catálogo CISA KEV (JSON descargable), y NVD para CVSS.

- **Hoja de cálculo o script Python** para cruzar CVE × CVSS × EPSS × KEV y ordenar por riesgo.
- **Gestor de tickets** (Jira, GitHub Issues) para simular el flujo de remediación.

> ⚠️ Escanea **solo** sistemas propios o con autorización escrita. Un escaneo no autorizado puede ser ilegal y disruptivo.

🧪 Laboratorio guiado — Construir un pipeline de priorización de VM

> 🧪 **Laboratorio ejecutable del programa:** `devsecops-pipeline` — practica allí la priorización por exposición real y la sección de **cobertura** del informe.

Ejercicio aplicado: escanearás un objetivo de laboratorio y construirás una cola de remediación priorizada por riesgo con SLAs.

1. **Inventaría el objetivo.** En la red host-only, identifica el activo (Metasploitable) y clasifícalo por criticidad de negocio (aquí: bajo, es lab).
2. **Escaneo no autenticado.** Lanza Greenbone/OpenVAS contra el objetivo. Guarda el reporte (lista de CVEs con CVSS).
3. **Escaneo autenticado.** Repite con credenciales del sistema y compara: observa cuántas vulnerabilidades adicionales aparecen y cuántos falsos positivos se reducen.
4. **Extrae las CVEs.** Exporta a CSV: `CVE`, `CVSS_base`, `activo`, `severidad`.
5. **Enriquece con EPSS.** Consulta la API de FIRST (`https://api.first.org/data/v1/epss?cve=CVE-XXXX-YYYY`) y añade la columna `epss`.
6. **Cruza con KEV.** Descarga el JSON de CISA KEV y marca `en_kev = sí/no` para cada CVE.
7. **Define la fórmula de priorización.** Regla ejemplo: `P1` si `en_kev = sí`; `P2` si `CVSS ≥ 7 y EPSS ≥ 0.1`; `P3` si `CVSS ≥ 7`; `P4` resto. Ordena la cola. El umbral 0.1 es un valor de ejemplo sin autoridad especial: cada organización fija el suyo (clase 369).
8. **Asigna SLAs.** P1 → 48 h, P2 → 15 días, P3 → 30 días, P4 → 90 días (valores de ejemplo del laboratorio; compáralos con los plazos de referencia de CISA BOD 26-04, que dependen de exposición, KEV, automatización e impacto: 3, 14 y 60 días). Registra fecha de detección y fecha límite.
9. **Simula remediación.** Crea tickets para los P1/P2, aplica (o simula) el parche y **re-escanea** para verificar cierre. Documenta una excepción formal para un P3 que no puedas parchear.
10. **Calcula métricas.** MTTR de los tickets cerrados, % remediado dentro de SLA, y densidad de vulnerabilidades por activo.

Entregable: CSV priorizado (CVE × CVSS × EPSS × KEV × prioridad × SLA) + tabla de métricas del ciclo.

✍️ Ejercicios

1. Dada una lista de 5 CVEs con su CVSS y EPSS, ordénalas por riesgo y justifica por qué EPSS puede subir o bajar la prioridad frente a CVSS solo.
2. Explica por qué una CVE con CVSS 6.5 en KEV puede ser más urgente que una CVSS 9.8 que no lo está.
3. Diseña una tabla de SLAs para tres niveles de criticidad de activo (crítico/importante/estándar) × cuatro prioridades.

4. Redacta una plantilla de excepción de riesgo con todos los campos obligatorios.
5. Calcula el MTTR de un conjunto de tickets con fechas de apertura/cierre dado.
6. Propón tres métricas para reportar al comité de riesgos y qué decisión habilita cada una.

📝 Reto verificable

Reto: entrega un pipeline de priorización de VM funcional que cruce, para al menos 15 CVEs reales, CVSS + EPSS + KEV y produzca una cola ordenada con SLAs asignados y métricas del ciclo.

Criterio de aceptación:

- Toda CVE presente en KEV queda al principio de la cola, independientemente de su CVSS; si se decide otra cosa (por ejemplo, el activo no es alcanzable), la razón queda documentada.
- La priorización usa las tres señales (severidad, probabilidad, explotación activa), no solo CVSS.
- Cada prioridad tiene un SLA numérico y una fecha límite calculada desde la detección.
- Se reportan al menos MTTR y % de remediación dentro de SLA.

⚠️ Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
"Priorizo solo por CVSS 9–10 y nunca acabo"	CVSS mide severidad, no riesgo. Añade EPSS y KEV para enfocar lo realmente explotable.
"Muchos falsos positivos en el reporte"	Escaneo no autenticado. Usa escaneo con credenciales para leer versiones/parches reales.
"El escáner tiró un servicio en producción"	Escaneo agresivo/inseguro sobre activos sensibles. Ajusta la política, usa ventanas y escaneo pasivo donde aplique.
"Las excepciones no vencen nunca"	Excepción sin fecha de revisión. Toda excepción debe tener dueño, compensaciones y caducidad.
"No sé si mejoramos"	Faltan métricas de tendencia. Mide MTTR, aging y % dentro de SLA mes a mes.
"Escaneo trimestral y me sorprenden 0-days"	Cadencia insuficiente. Combina escaneo continuo con alimentación de threat intel (KEV).

❓ Preguntas frecuentes

❓ **¿CVSS o EPSS?** Ambos, más KEV. CVSS te dice *cuán grave* es técnicamente; EPSS, *qué tan probable* es que la exploten; KEV, si *ya la están explotando*. Priorizar con las tres reduce ruido y enfoca el esfuerzo.

❓ **¿Cada cuánto debo escanear?** NIST SP 800-40 Rev.4 promueve gestión continua. En la práctica: escaneo continuo/semanal para activos expuestos, mensual para internos, y re-escaneo inmediato tras remediar o tras una entrada nueva en KEV.

❓ **¿Parcheo o mitigo?** El parche es la remediación definitiva; cuando no es posible a tiempo, aplica mitigaciones compensatorias (segmentación, WAF, deshabilitar el servicio) y documenta la excepción con fecha de revisión.

❓ **¿Qué métricas presento a la dirección?** Tendencia de riesgo abierto, MTTR por criticidad, % de remediación dentro de SLA y exposición a KEV. Son accionables y muestran mejora en el tiempo.

🔗 Referencias

- 🏢 **En la empresa:** el ciclo se gestiona con plataformas de VM como **Qualys VMDR**, **Tenable.io** y **Rapid7 InsightVM**; el enfoque (descubrir → priorizar CVSS/EPSS/KEV → SLA → verificar) es el mismo.
- NIST. *Guide to Enterprise Patch Management Planning* — SP 800-40 Rev.4.
- Chapple & Seidl. *CompTIA CySA+ Study Guide (CS0-003)*, Sybex.
- FIRST. *EPSS — Exploit Prediction Scoring System* — first.org/epss.
- CISA. *Known Exploited Vulnerabilities Catalog* — cisa.gov/known-exploited-vulnerabilities-catalog.
- FIRST. *CVSS v3.1/v4.0 Specification* — first.org/cvss.

📥 Material descargable

- 📄 Guía en PDF — versión imprimible de esta clase.
- 🎞️ Presentación (PPTX) — deck para proyectar en clase.

⬅️ Clase anterior

Clase 317 — Seguridad física y ambiental

➡️ Siguiente clase

Clase 319 — Análisis avanzado de phishing y correo malicioso